

INGETIS / SUP DE VINCI — CPI BACHELOR RNCP 38478
SPÉCIALITÉ SYSTÈMES, RÉSEAUX & CYBERSÉCURITÉ — B4

DOCUMENT D'ARCHITECTURE TECHNIQUE

DAT — Épreuve certifiante BC3

Superviser la mise en œuvre d'un projet informatique

PROJET	SPÉCIALITÉ
CYNA — Cybersecurity SaaS (EDR / XDR / SOC)	 SR/CYBER — Systèmes, Réseaux & Cybersécurité (B4)

GROUPE / ÉQUIPE	DATE DE DÉPÔT FINAL
Groupe n°1 Promo 2025–2026	19/06/2026

MEMBRES ET SECTIONS RÉDIGÉES

- Hugo DELOGE — Sections : **DevOps & Cloud / Architecte Cloud**
- Corentin GUIHAIRE — Sections : **Architecte Sécurité**
- Ugo PINCIROLI — Sections : **Ingénieur Réseau**
- Lucas MANICORD — Sections : **Responsable Infrastructure**
- Praveen SOUBRAMANIENT — Sections : **Administrateur Système**

SOMMAIRE

[PARTIE 1 — VISION ET OBJECTIFS](#)

[1.1 Contexte CYNA — Infrastructure](#)

[Enjeux de Sécurité](#)

[Choix d'Architecture](#)

[Réseau](#)

[1.2 Vision architecturale](#)

[1.3 Objectifs techniques et sécurité](#)

[PARTIE 2 — ARCHITECTURE RÉSEAU ET INFRASTRUCTURE](#)

[2.1 Schéma réseau logique](#)

[2.2 Segmentation réseau — Plan d'adressage](#)

[Interfaces OPNsense \(FW-OPN01\)](#)

[Plages DHCP — Kea DHCPv4](#)

[2.3 Règles de filtrage \(pare-feu / ACL\)](#)

[2.4 Inventaire des serveurs et services](#)

[PARTIE 3 — INFRASTRUCTURE AS CODE ET DÉPLOIEMENT](#)

[3.1 Provisionning avec OpenTofu \(Terraform\)](#)

[3.2 Configuration avec Ansible](#)

[3.3 Approche de déploiement des services](#)

[3.4 Guide de déploiement](#)

[PARTIE 4 — SÉCURITÉ ET GESTION DES RISQUES](#)

[4.1 Politique de sécurité de l'information](#)

[4.2 Analyse de risques](#)

[4.3 Configuration SIEM Wazuh — Règles et alertes](#)

[4.4 Durcissement des systèmes \(Hardening\)](#)

[Durcissement des serveurs Linux et de l'Infrastructure](#)

[PARTIE 5 — TESTS, VALIDATION ET VÉRIFICATION SÉCURITÉ](#)

[5.1 Plan de tests](#)

[5.2 Résultats des tests de sécurité](#)

[Justification de la Non-Exécution des Tests OWASP ZAP](#)

[5.3 Preuves de détection Wazuh](#)

[5.4 Anomalies et corrections](#)

[PARTIE 6 — DOCUMENTATION ET BILAN TECHNIQUE](#)

[6.1 Index de la documentation livrée](#)

[6.2 Procédures d'exploitation \(Runbooks\)](#)

[Sauvegarde des machines virtuelles Proxmox](#)

[Création d'un snapshot](#)

[Restauration d'une machine virtuelle](#)

[Validation de la procédure : Un test de restauration a été réalisé avec succès sur une machine virtuelle Ubuntu de test. La machine a été sauvegardée via Proxmox, supprimée puis restaurée à partir du fichier de sauvegarde. La récupération du système et des données a été vérifiée après restauration.](#)

[Vérification de l'espace de stockage](#)

[6.3 Bilan technique collectif](#)

Responsable	Rôle Principal	Responsabilités Clés
Corentin GUIHAIRE	Architecte Sécurité	SIEM Wazuh, analyse de logs, détection (MITRE), règles de corrélation, IDS/IPS Suricata, MFA, tests d'intrusion
Ugo PINCIROLI	Ingénieur Réseau	Interconnexion réseau Genève-Paris, Firewall OPNsense, VLANs, DHCP/DNS
Hugo DELOGE	DevOps & Cloud / Architecte Cloud	Provisioning Azure (Entra ID), Terraform/OpenTofu, Ansible, IaC, supervision Zabbix
Praveen SOUBRAMANIEN	Administrateur Système	Active Directory, DNS, GPO, jonction et gestion des postes Windows
Lucas MANICORD	Responsable Infrastructure	Hyperviseur Proxmox, stockage, sauvegardes, PRA/PCA

PARTIE 1 — VISION ET OBJECTIFS

1.1 Contexte CYNA — Infrastructure

Enjeux de Sécurité

Le projet de modernisation de CYNA, experte en cybersécurité, vise une refonte de son système d'information pour soutenir son expansion, avec un siège à Genève, une filiale à Paris et le lancement d'une plateforme SaaS. En tant qu'opérateur SOC, l'entreprise doit garantir une sécurité exemplaire pour protéger les données de ses clients et sa propre infrastructure. L'enjeu sécuritaire majeur repose sur une approche « Zero Trust » : aucun utilisateur ou appareil n'est approuvé par défaut, et les accès d'administration sont protégés par une authentification multifacteur (MFA TOTP). Cette posture s'appuie sur une micro-segmentation qui isole les réseaux bureautiques (Genève, Paris), les serveurs internes et la DMZ. Des agents Wazuh, en remplacement des solutions EDR propriétaires, sont déployés sur les postes et serveurs. La centralisation des logs vers le SIEM Wazuh permet au SOC d'assurer une surveillance continue.

Choix d'Architecture

Face aux exigences de disponibilité et aux contraintes réglementaires européennes et suisses, l'équipe a retenu une architecture hybride. Les services critiques et souverains — l'annuaire Active Directory (qui s'affranchit des licences Microsoft 365) et les serveurs internes — sont conservés on-premise à Genève sur un hyperviseur Proxmox VE. La dimension cloud repose sur Microsoft Azure (comptes Azure for Students). Un tenant Entra ID (cynaprojet.onmicrosoft.com) a été déployé avec les utilisateurs et groupes de sécurité de l'organisation, illustrant la couche d'identité cloud d'une architecture hybride. Ce tenant n'est toutefois pas synchronisé avec l'Active Directory on-premise ([cyna.local](#)) : la synchronisation d'annuaire (Entra Connect) requiert une licence non attribuable au tenant dans le cadre des comptes Azure for Students. L'Active Directory on-premise demeure donc la source de vérité unique pour l'authentification interne. La partie compute Azure, prévue pour la couche SaaS et le site vitrine, n'a pas pu être déployée en raison du quota bloquant les machines virtuelles de la série B ; le site vitrine est par conséquent hébergé on-premise sur SRV-DMZ, derrière le pare-feu OPNsense. La haute disponibilité (cluster, redondance) constitue une cible de production, non implémentée dans cette maquette mono-hyperviseur (cf. §6.3).

Réseau

L'interconnexion entre les sites et le cloud repose sur le pare-feu open-source OPNsense. La segmentation en VLAN et le filtrage strict assurent l'isolation entre les zones (postes Genève/Paris, serveurs, DMZ). Les deux sites partageant le même hyperviseur et le même pare-feu, aucun tunnel site-à-site (VPN/ZTNA) n'est mis en place : cette brique, prévue au cadrage, est volontairement écartée car sans objet dans ce contexte mono-hyperviseur, et serait implémentée via IPsec ou une solution ZTNA dédiée en production. L'automatisation est pilotée par l'Infrastructure as Code : OpenTofu (compatible Terraform) provisionne les machines virtuelles sur Proxmox, tandis qu'Ansible

gère la configuration des serveurs. La supervision opérationnelle s'appuie sur Zabbix 7.4 (open-source), complémentaire du SIEM Wazuh : Zabbix couvre la disponibilité et les métriques, Wazuh la sécurité — les deux outils coexistent. L'équipe adopte une méthode hybride Scrum-ban pour articuler l'agilité logicielle et le suivi continu de l'infrastructure.

1.2 Vision architecturale

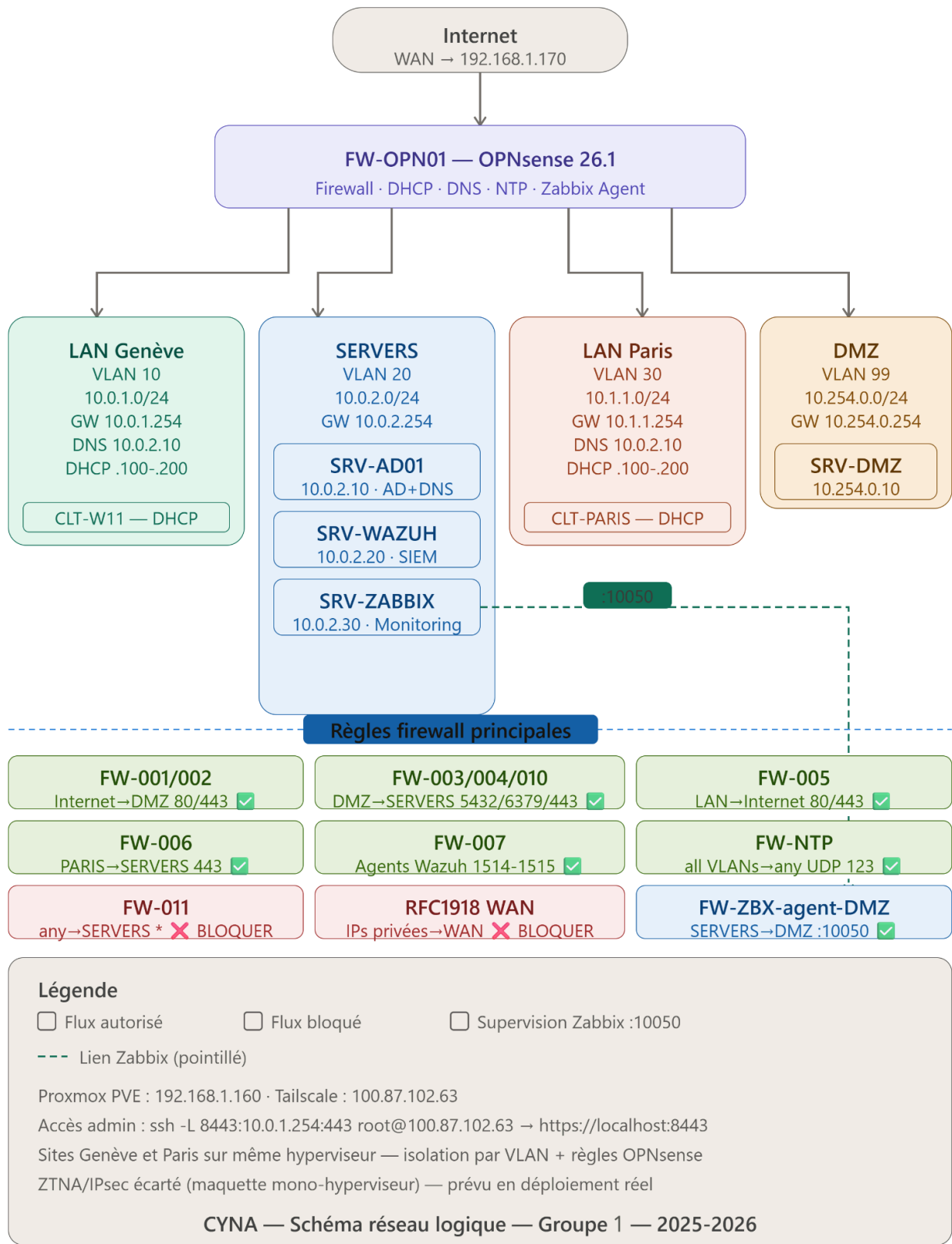
- **Infrastructure as Code (IaC)** : OpenTofu/Terraform (provider [bpg/proxmox](#)) pour le provisionnement des VM et de la configuration cloud Azure ; Ansible pour la configuration des serveurs, services réseau et pare-feux.
- **Segmentation réseau** : Micro-segmentation isolant les zones Bureautique Genève, Serveurs, Bureautique Paris et DMZ via VLAN sur OPNsense.
- **Sécurité by design** : Zero Trust (aucun appareil/utilisateur approuvé par défaut), authentification renforcée par MFA TOTP sur les accès d'administration ; isolation par micro-segmentation VLAN et filtrage OPNsense (solution ZTNA dédiée écartée en maquette). Agents Wazuh (EDR open-source) sur terminaux et serveurs.
- **Observabilité** : Centralisation des logs vers le SIEM Wazuh + OpenSearch pour le SOC, et supervision opérationnelle des métriques via Zabbix 7.4.

1.3 Objectifs techniques et sécurité

Objectif	Indicateur de succès	Priorité
Segmentation réseau VLAN opérationnelle	Isolation zones vérifiée (tests ping/nmap)	Critique
SIEM Wazuh : agents déployés sur tous les endpoints	Dashboards Wazuh actifs avec alertes	Haute
Infrastructure déployable via IaC (OpenTofu + Ansible)	Déploiement reproductible et documenté	Haute
Durcissement OS (GPO & Scripts)	Application homogène sur les postes	Moyenne
Détection d'intrusions (IDS/IPS) fonctionnelle	Alerte/Blocage générés sur attaques simulées	Haute

PARTIE 2 — ARCHITECTURE RÉSEAU ET INFRASTRUCTURE

2.1 Schéma réseau logique



Le schéma représente l'architecture réseau logique de l'infrastructure CYNA déployée sur Proxmox VE. OPNsense constitue le cœur du dispositif réseau, assurant le routage inter-VLAN, le filtrage firewall et la distribution DHCP (Kea) pour l'ensemble des zones. La résolution DNS du domaine cyna.local est déléguée au contrôleur Active Directory (SRV-AD01, 10.0.2.10), OPNsense (Unbound) assurant la résolution récursive en amont. Quatre segments réseau fonctionnels isolés sont définis (le VLAN 1 Management physique étant traité à part) : le LAN Genève (postes collaborateurs), le VLAN SERVERS (infrastructure), le LAN Paris (filiale) et la DMZ (services exposés). L'interconnexion entre les sites Genève et Paris est assurée par la segmentation VLAN sur le même hyperviseur Proxmox, les règles firewall OPNsense garantissant l'isolation et le contrôle des flux inter-sites. En production réelle, cette liaison serait remplacée par un tunnel IPsec site-à-site ou une solution ZTNA dédiée.

2.2 Segmentation réseau — Plan d'adressage

La segmentation réseau repose sur cinq zones distinctes gérées par le firewall OPNsense. Chaque zone dispose de sa propre plage d'adressage, de sa gateway dédiée et de ses règles de filtrage. Le principe du moindre privilège s'applique : seuls les flux explicitement autorisés sont permis entre les zones.

Zone / VLAN	Plage IP	Rôle	Gateway	Accès autorisé
VLAN 1 — Management (Physique)	192.168.1.0/24	Réseau physique — Proxmox PVE + WAN OPNsense	192.168.1.1 (box)	Accès Proxmox (8006), WAN OPNsense (DHCP), Tailscale (100.87.102.63)
VLAN 10 — LAN Genève (Postes)	10.0.1.0/24	Postes de travail collaborateurs (siège Genève)	10.0.1.254	Internet sortant filtré (80/443), accès SERVERS via OPNsense
VLAN 20 — SERVERS	10.0.2.0/24	Serveurs infrastructure (AD, DNS, SIEM, Monitoring)	10.0.2.254	LAN vers SERVERS filtré, isolation inter-VLAN stricte (FW-011)
VLAN 30 — LAN Paris	10.1.1.0/24	Postes de travail filiale Paris	10.1.1.254	Internet sortant filtré, accès SERVERS limité (443, Wazuh 1514-1515)
VLAN 99 — DMZ	10.254.0.0/24	Services exposés, reverse proxy Nginx	10.254.0.254	Internet entrant (80/443 uniquement), DMZ vers SERVERS filtré

Interfaces OPNsense (FW-OPN01)

Interface	Identifiant	IP	Masque	Rôle
WAN (vtnet0)	wan	192.168.1.170	DHCP	Accès Internet via box physique (VLAN 1)
LAN — VLAN 10 (vtnet1)	lan	10.0.1.254	/24	Gateway postes Genève
SERVERS — VLAN 20 (vtnet2)	opt1	10.0.2.254	/24	Gateway serveurs infrastructure

PARIS — VLAN 30 (vtnet3)	opt2	10.1.1.254	/24	Gateway postes Paris
DMZ — VLAN 99 (vtnet4)	opt3	10.254.0.254	/24	Gateway DMZ / services exposés

Plages DHCP — Kea DHCPv4

Interface	Plage DHCP	DNS distribué	Domaine	Routeur
LAN Genève	10.0.1.100 — 10.0.1.200	10.0.2.10 (SRV-AD01)	cyna.local	10.0.1.254
SERVERS	10.0.2.100 — 10.0.2.200	127.0.0.1 (auto AD)	cyna.local	10.0.2.254
LAN Paris	10.1.1.100 — 10.1.1.200	10.0.2.10 (SRV-AD01)	cyna.local	10.1.1.254
DMZ	10.254.0.100 — 10.254.0.200	10.0.2.10 (SRV-AD01)	cyna.local	10.254.0.254

2.3 Règles de filtrage (pare-feu / ACL)

Les règles suivantes sont implémentées sur OPNsense 26.1. Elles appliquent le principe du moindre privilège : tout trafic non explicitement autorisé est bloqué par défaut. L'ordre des règles est important — OPNsense les évalue de haut en bas et s'arrête à la première correspondance.

Règle	Source	Destination	Port/Proto	Interface	Action	Justification
FW-001	Internet (WAN)	DMZ	443/TCP	WAN	AUTORISER	Accès HTTPS services CYNA exposés
FW-002	Internet (WAN)	DMZ	80/TCP	WAN	AUTORISER	Redirection HTTP vers HTTPS (Nginx)
FW-003	DMZ	SERVERS	5432/TCP	SERVERS	AUTORISER	API vers PostgreSQL
FW-004	DMZ	SERVERS	6379/TCP	SERVERS	AUTORISER	API vers Redis (cache sessions)
FW-005	LAN Genève	Internet	80, 443/TCP	LAN	AUTORISER	Navigation web collaborateurs Genève
FW-006	LAN Paris	SERVERS	443/TCP	PARIS	AUTORISER	Filiale Paris vers services internes
FW-007	Tous VLANs	SERVERS	1514-1515/TCP+UDP	SERVERS	AUTORISER	Agents Wazuh vers SIEM (collecte logs)
FW-010	DMZ	SERVERS	443/TCP	DMZ	AUTORISER	Tunnel DMZ vers serveurs internes
FW-011	any	SERVERS	any	SERVERS	BLOQUER	Isolation totale SERVERS par défaut
FW-S01	SERVERS	any	53/UDP	SERVERS	AUTORISER	DNS sortant SERVERS
FW-S02	SERVERS	any	80/TCP	SERVERS	AUTORISER	HTTP sortant SERVERS (apt/mises à jour)

FW-S03	SERVERS	any	443/TCP	SERVERS	AUTORISER	HTTPS sortant SERVERS
FW-S04	SERVERS	any	ICMP	SERVERS	AUTORISER	Ping sortant SERVERS (diagnostic)
FW-P01	LAN Paris	any	53/UDP	PARIS	AUTORISER	DNS sortant Paris
FW-P02	LAN Paris	any	80/TCP	PARIS	AUTORISER	HTTP sortant Paris
FW-P03	LAN Paris	any	443/TCP	PARIS	AUTORISER	HTTPS sortant Paris
FW-P04	LAN Paris	any	ICMP	PARIS	AUTORISER	Ping sortant Paris (diagnostic)
FW-P05	LAN Paris	SERVERS	1514-1515/TCP	PARIS	AUTORISER	Agents Wazuh Paris vers SIEM Genève
FW-D01	DMZ	any	53/UDP	DMZ	AUTORISER	DNS sortant DMZ
FW-D02	DMZ	any	443/TCP	DMZ	AUTORISER	HTTPS sortant DMZ
FW-D03	any	any	any	DMZ	BLOQUER	Blocage tout le reste en DMZ
FW-NTP	Tous VLANs	any	123/UDP	Toutes	AUTORISER	Synchronisation NTP (prérequis MFA/TOTP)
FW-ZBX	SERVERS	DMZ	10050/TCP	SERVERS	AUTORISER	SRV-ZABBIX vers agent Zabbix SRV-DMZ
RFC1918	IPs privées RFC1918	WAN	any	WAN	BLOQUER	Anti-spoofing — bloque toute IP privée entrante sur WAN

NAT Outbound : génération automatique activée sur OPNsense — toutes les interfaces (LAN, SERVERS, PARIS, DMZ) sont nattées vers le WAN pour l'accès Internet. Aucune configuration manuelle requise.

Les règles FW-003 et FW-004 (DMZ → PostgreSQL 5432 / Redis 6379) anticipent la couche applicative SaaS prévue au cadrage. Les services de base de données et de cache associés ne sont pas déployés dans la maquette (cf. §1.1 et bilan §6.3, compute Azure non provisionné) ; ces règles préparent l'architecture cible sans service actif en backend à ce stade.

2.4 Inventaire des serveurs et services

Hôte	VMI D	OS	Rôle et services	VLAN	IP
fw-opn01	100	OPNsense 26.1	Pare-feu, routage inter-VLAN, DHCP (Kea), DNS (Unbound), IDS/IPS (Suricata), MFA TOTP, agent Zabbix	Passerelle de chaque VLAN	.254 par interface
SRV-AD01	101	Windows Server 2022	Contrôleur de domaine <code>cyna.local</code> , DNS intégré AD, GPO, agent Wazuh + Zabbix	20	10.0.2.10
SRV-WAZUH	102	Ubuntu 26.04	SIEM Wazuh 4.14 (Manager + OpenSearch + Dashboard), agent Zabbix	20	10.0.2.20
SRV-ZABBIX	107	Ubuntu 26.04	Supervision Zabbix 7.4 (PostgreSQL, Apache, PHP-FPM), agent Zabbix	20	10.0.2.30
SRV-DMZ	105	Ubuntu 26.04	Site vitrine nginx, agent Wazuh, agent Zabbix	99	10.254.0.10
CLT-W11	103	Windows 11	Poste de travail joint au domaine, agents Wazuh + Zabbix	10	10.0.1.100
CLT-W11-PARIS	104	Windows 11	Poste de travail joint au domaine, agents Wazuh + Zabbix	30	10.1.1.100

PARTIE 3 — INFRASTRUCTURE AS CODE ET DÉPLOIEMENT

3.1 Provisionning avec OpenTofu (Terraform)

L'infrastructure virtuelle est provisionnée de manière déclarative via OpenTofu (fork open source de Terraform) en utilisant le provider `bpg/proxmox`. L'état est stocké localement et le code source est versionné sur GitHub.

Spécificités d'implémentation :

- Utilisation du bloc `cdrom {}` natif pour l'attachement des ISOs d'installation (OS et VirtIO).
- Authentification SSH automatisée vers l'hyperviseur via une clé ED25519 dédiée.
- Gestion des variables sensibles via les variables d'environnement (`TF_VAR_*`).
- Résolution stricte du "drift" de configuration pour que le code reflète l'état exact des ressources (MAC adresses, BIOS OVMF, TPM).

3.2 Configuration avec Ansible

La configuration post-déploiement est gérée par Ansible.

Structure et sécurisation :

- L'inventaire est segmenté par groupes fonctionnels (`soc`, `network_devices`, `dmz`).
- L'authentification s'effectue via une clé SSH sécurisée par passphrase (chargée dans `ssh-agent`).
- Les secrets (clés API OPNsense, mots de passe sudo) sont chiffrés à l'aide d'**Ansible Vault**.
- Utilisation de `ansible.builtin.uri` pour automatiser la configuration du DHCP via l'API REST d'OPNsense.
- L'option `pipelining = True` et des ajustements sur `sudo-rs` ont été appliqués pour assurer la compatibilité avec Ubuntu 26.04.

3.3 Approche de déploiement des services

En maquette, aucune stack de conteneurs n'a été déployée : l'isolation des services repose sur la virtualisation au niveau VM (un service par VM sur Proxmox) plutôt que sur la conteneurisation. Ce choix est cohérent avec une maquette mono-hyperviseur où chaque brique (AD, Wazuh, Zabbix, nginx) dispose de sa propre VM dédiée, offrant une isolation forte et une gestion reproductible via l'IaC (OpenTofu) et la configuration automatisée (Ansible).

La conteneurisation (Docker/Kubernetes) était envisagée au cadrage pour la couche SaaS/e-commerce dans le cloud — couche non déployée en raison des restrictions des comptes Azure for Students (cf. §1.1 et bilan §6.3). En production, les services exposés seraient conteneurisés pour la scalabilité ; la démarche IaC mise en place reste directement transposable à un déploiement conteneurisé.

3.4 Guide de déploiement

Prérequis : Proxmox VE 8.x accessible, OpenTofu ≥ 1.12, Ansible-core, Git.

Étape 1 : Provisioning de l'infrastructure (OpenTofu)

```
git clone https://github.com/Hugodlg91/cyna-infra.git
cd cyna-infra/terraform
```

```
# Définition du token d'API Proxmox (variable masquée)
export TF_VAR_proxmox_api_token="votre_token_secret"
```

```
tofu init
tofu plan
tofu apply
```

Étape 2 : Déploiement des configurations (Ansible)

```
cd ../ansible
```

```
# Chargement de la clé SSH sécurisée par passphrase
```

```
eval $(ssh-agent -s)
```

```
ssh-add ~/.ssh/ansible_cyna
```

```
# Configuration du DHCP OPNsense via API REST
```

```
ansible-playbook playbooks/opnsense.yml --ask-vault-pass
```

```
# Déploiement de Wazuh Manager (All-in-one)
```

```
ansible-playbook playbooks/wazuh-server.yml --ask-vault-pass
```

```
# Déploiement du serveur Web DMZ et de l'agent Wazuh Linux
```

```
ansible-playbook playbooks/nginx-dmz.yml --ask-vault-pass
```

```
ansible-playbook playbooks/wazuh-agent-linux.yml --ask-vault-pass
```

```
ansible-playbook playbooks/zabbix-agent-linux.yml --ask-vault-pass
```

Étape 3 : Active Directory et GPO (PowerShell / Windows) L'automatisation Windows n'est pas gérée par Ansible mais par la structure d'annuaire :

1. Promotion du contrôleur de domaine **SRV-AD01** et jonction des postes clients (**CLT-W11-GENEVE**, **CLT-W11-PARIS**).
2. Déplacement des objets ordinateurs dans l'OU **Ordinateurs**.
3. Application de la **GPO-Deploy-Wazuh** : Le script PowerShell **Deploy-Wazuh.ps1** (situé dans le SYSVOL) s'exécute silencieusement au démarrage des postes pour installer l'agent de sécurité.
4. Application de la **GPO-Deploy-Zabbix** pour la supervision.

Étape 4 : Vérification des services

- **Wazuh** : Accès au dashboard via tunnel SSH sur **https://10.0.2.20**. Vérification dans la section *Agents* que les serveurs et postes clients sont en statut **Active**.
- **Zabbix** : Accès à l'interface via tunnel SSH sur **http://10.0.2.30/zabbix**. Vérification de la disponibilité (ZBX au vert) des agents.

PARTIE 4 — SÉCURITÉ ET GESTION DES RISQUES

4.1 Politique de sécurité de l'information

La politique de sécurité de l'infrastructure CYNA repose sur une approche Zero Trust. Les directives suivantes ont été appliquées :

- **Contrôle d'accès** : Application du principe du moindre privilège sur l'ensemble de l'infrastructure, avec l'utilisation de comptes de service dédiés. La micro-segmentation VLAN sur OPNsense impose un blocage par défaut (FW-011 : isolation totale du VLAN SERVERS), seuls les flux explicitement nécessaires étant autorisés. L'accès d'administration aux machines internes ne se fait jamais en direct mais via des tunnels SSH rebondissant sur l'hyperviseur (Tailscale), ce qui réduit la surface d'exposition.
- **Gestion des identités** : L'authentification multi-facteurs par TOTP est mise en place sur l'accès d'administration du pare-feu OPNsense (serveur d'authentification TOTP local, jeton 6 chiffres / fenêtre 30 s), via un compte dédié. Le compte `root` est volontairement maintenu sans MFA comme accès de secours, afin d'éviter tout verrouillage hors de l'interface qui bloquerait l'administration partagée de la maquette. L'accès SSH aux serveurs Linux s'effectue exclusivement par clés cryptographiques (ED25519), l'authentification par mot de passe étant désactivée (`PasswordAuthentication no`, `UsePAM no`). L'annuaire Active Directory `cyna.local` centralise les identités internes, avec une politique de mot de passe imposée par GPO (12 caractères minimum, complexité requise).
- **Chiffrement** : Les communications avec le dashboard Wazuh et l'interface d'administration OPNsense transitent en HTTPS/TLS. Les secrets d'automatisation (clés d'API OPNsense, mots de passe sudo) sont chiffrés au repos en AES-256 via Ansible Vault.
- **Gestion des logs** : Tous les événements de sécurité des postes et serveurs sont centralisés sur le SIEM Wazuh (manager 10.0.2.20) via les agents déployés. Le seuil d'enregistrement est fixé au niveau 3 (`log_alert_level=3`), couvrant les connexions échouées, les modifications de fichiers critiques et les élévations de privilèges. L'intégrité de la configuration et du ruleset de Wazuh lui-même est surveillée par FIM, ce qui protège l'outil de supervision contre une altération.
- **Réponse aux incidents** : La détection s'appuie sur les règles Wazuh, dont la règle personnalisée 100100 (≥3 échecs d'authentification en 120 s → alerte de niveau 10, mappée MITRE ATT&CK T1110), et sur l'IPS Suricata en mode blocage actif sur les interfaces DMZ et WAN. Le blocage inline a été validé de bout en bout (coupure d'une requête au User-Agent malveillant, signature SID 2002877). En cas de compromission, l'isolation immédiate d'une zone reste possible via les règles OPNsense.

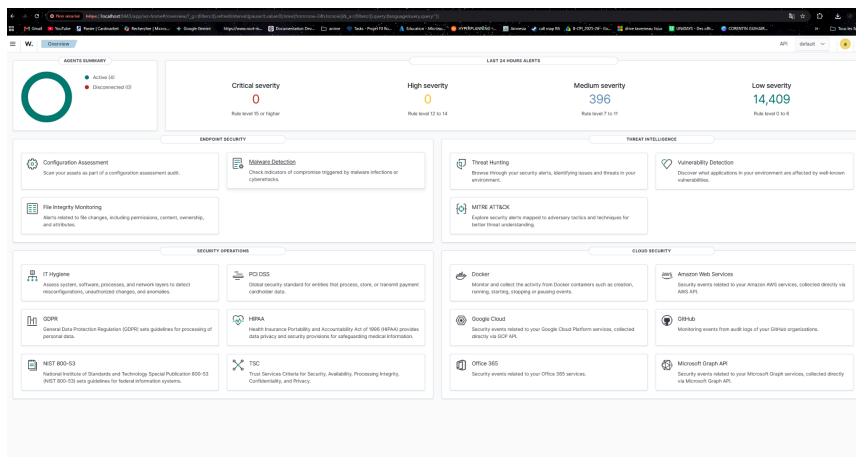
4.2 Analyse de risques

Risque identifié	Probabilité	Impact	Mesure de mitigation	Statut
Accès SSH non autorisé	Haute	Critique	Clés SSH uniquement (mot de passe désactivé), accès via tunnel SSH rebond, VLAN gestion isolé	Implémenté
Intrusion latérale réseau	Haute	Critique	Micro-segmentation VLAN + ACL strictes (blocage par défaut FW-011)	Implémenté
Compromission credentials admin	Moyenne	Critique	MFA TOTP sur OPNsense (compte admin dédié) + secrets chiffrés Ansible Vault	Implémenté
Intrusion réseau / trafic malveillant (DMZ/WAN)	Haute	Élevé	IPS Suricata en mode blocage (ET Open) — blocage validé SID 2002877	Implémenté
Exfiltration données (BDD)	Moyenne	Élevé	Isolation VLAN SERVERS + supervision Wazuh + FIM	Implémenté
Altération / suppression des logs	Faible	Élevé	Logs centralisés sur SIEM distant + FIM sur la config Wazuh	Implémenté
Tentative de brute-force authentification	Moyenne	Élevé	Règle de corrélation personnalisée 100100 (niveau 10, MITRE T1110)	Implémenté

4.3 Configuration SIEM Wazuh — Règles et alertes

- **Agents déployés** : Le déploiement des agents Wazuh a été réalisé via la commande d'installation générée par le dashboard Wazuh (téléchargement du MSI et enregistrement automatique auprès du manager). Les agents sont actuellement actifs et remontent leurs logs depuis l'ensemble du parc supervisé, incluant le contrôleur de domaine SRV-AD01, le poste client CLT-W11, ainsi que le manager lui-même en auto-surveillance (agent interne 000).
- **Règles personnalisées activées** : Afin de durcir la surveillance, le moteur d'analyse a été enrichi via le fichier `local_rules.xml`. Le système surveille désormais activement les modifications du répertoire critique `C:\Users` sur le contrôleur de domaine (module FIM, temps réel), la configuration et le ruleset du SIEM lui-même (`/var/ossec/etc` et `/var/ossec/ruleset`), et inclut notre règle sur-mesure **100100** qui détecte au moins 3 échecs d'authentification en 120 secondes en déclenchant une alerte critique de **niveau 10**, mappée MITRE ATT&CK T1110 (Brute Force).
- **Intégrations Slack/email (non réalisé)** : Le déclenchement automatique de notifications externes (webhook Slack, alerte email) sur les alertes critiques (niveau 12+) n'a pas été mis en œuvre dans le temps imparti. Le seuil de niveau 12 est déjà configuré côté Wazuh comme seuil de notification, mais aucun canal de sortie (Slack, SMTP) n'y a été raccordé. Cette intégration est identifiée comme une amélioration prioritaire pour fiabiliser la réactivité du SOC, le périmètre de cette session ayant porté en priorité sur la détection elle-même (FIM, règles de corrélation, IDS/IPS) plutôt que sur la chaîne de notification.
- **SCA / Security Configuration Assessment (non réalisé)** : Le module SCA, qui permet d'auditer en continu la conformité des systèmes aux benchmarks CIS, n'a pas été activé sur cette infrastructure. Le hardening des serveurs n'a pas fait l'objet d'un script Ansible dédié dans le temps disponible ; seules des vérifications manuelles ponctuelles ont été réalisées. L'activation du SCA et la mesure d'un score de conformité par serveur restent une piste d'amélioration pour objectiver le niveau de durcissement OS, en complément de la détection comportementale déjà en place.

Vue globale du tableau de bord SIEM Ce tableau de bord centralise la supervision de l'infrastructure CYNA. Il confirme le bon déploiement de la solution en affichant l'état des agents Wazuh actifs sur nos terminaux et serveurs, tout en offrant une visibilité en temps réel sur le volume d'événements de sécurité ingérés.



Intégration de la règle personnalisée 100100 Cette capture illustre l'intégration de notre règle sur-mesure (ID : 100100) au sein du gestionnaire d'alertes. Conçue pour répondre aux enjeux spécifiques de notre architecture, elle permet d'affiner les capacités du SOC en ciblant des comportements critiques (Niveau 10) qui ne sont pas couverts par les signatures standards.

```

1 <!-- Local rules -->
2
3 <!-- Modify it at your will -->
4 <!-- Copyright (C) 2015, Wazuh Inc. -->
5
6 <!-- Example -->
7 <!-- group name="local_syslog_smbd," -->
8
9 <!--
10 Dec 19 01:02:02 host sub[1234]: failed none for root from 1.1.1.1 port 1086 ssh2
11 -->
12 <!-- rule id="100000" level="0" -->
13 <!-- if condition -->
14 <!-- script -->
15 <!-- description -->
16 <!-- group -->
17 </rule>
18
19 </group>
20
21 <!-- Detection de scan / reconnaissance : échec d'authentification répétés depuis une même source -->
22 <!-- group name="local_authentication_failed_repeated_scan" -->
23 <!-- rule id="100100" level="10" frequency="2" timeframe="12h" -->
24 <!-- if condition -->
25 <!-- description -->
26 <!-- group -->
27 </rule>
28
29 </group>
30
31 </group>

```

4.4 Durcissement des systèmes (Hardening)

Durcissement des serveurs Linux et de l'Infrastructure

L'approche de sécurité pour les serveurs Linux privilégie la réduction de la surface d'attaque native et la sécurisation stricte des accès distants, le filtrage réseau étant délégué au pare-feu central OPNsense.

Mesure	Référentiel	Implémentée via	Statut
Authentification SSH stricte (Clés uniquement)	ANSSI / CIS	sshd_config (PasswordAuthentication no, UsePAM no) + suppression de la règle cloud-init permissive	Implémenté (SRV-DMZ, etc.)
Réduction de la surface d'attaque OS	CIS	Utilisation des images Ubuntu 26.04 LTS "minimized" (sans paquets superflus)	Implémenté (SRV-DMZ, SRV-ZABBIX)
MFA sur les accès d'administration	Zero Trust	Serveur TOTP local OPNsense — actif sur compte admin dédié, root laissé en accès de secours	Implémenté
Surveillance d'intégrité (FIM) des configs critiques	CIS	Agent interne Wazuh (surveillance des répertoires /etc, /var/ossec/etc...)	Implémenté
Sécurisation des secrets d'automatisation	Bonnes pratiques DevOps	Chiffrement AES-256 via Ansible Vault pour les mots de passe sudo et clés API	Implémenté

Durcissement des postes Windows (Hardening via GPO)

Le durcissement des postes de travail Windows est assuré par des stratégies de groupe (GPO) appliquées depuis le contrôleur de domaine Active Directory **cyna.local**. Ces stratégies sont liées à l'unité d'organisation Ordinateurs (ainsi qu'au domaine pour la politique de mot de passe), ce qui garantit leur application automatique et uniforme sur tous les postes des deux sites (Genève et Paris). Cette approche centralisée évite toute configuration manuelle poste par poste et empêche les utilisateurs de contourner les mesures de sécurité.

Mesure	Référentiel	Implémentée via	Statut
--------	-------------	-----------------	--------

Politique de mot de passe (12 caractères min., complexité requise)	ANSSI / CIS	GPO-Password-Policy (domaine)	Implémenté
Blocage des périphériques de stockage USB	ANSSI / CIS	GPO-Securite-Postes (OU Ordinateurs)	Implémenté
Pare-feu Windows Defender forcé (profils Domaine, Privé, Public)	CIS	GPO-Securite-Postes (OU Ordinateurs)	Implémenté
Verrouillage automatique de session après 10 min d'inactivité	ANSSI / CIS	GPO-Securite-Postes (OU Ordinateurs)	Implémenté
Application vérifiée et cohérente sur les 2 sites (gpresult)		Rapports GPO (Genève + Paris)	Vérifié

PARTIE 5 — TESTS, VALIDATION ET VÉRIFICATION SÉCURITÉ

5.1 Plan de tests

Réf Test	Objectif du Test	Procédure / Méthode	Résultat Attendu	Statut
T-01	Cartographie réseau & Audit des ports ouverts	Exécution d'un scan complet via l'outil nmap sur la cible.	Identification précise des services actifs et détection d'éventuels ports non durcis.	OK
T-02	Simulation d'attaque par Brute Force	Tentatives de connexions répétées avec de mauvais identifiants (SSH ou Web).	Déclenchement de la règle personnalisée 100100 et génération d'une alerte.	OK
T-03	Génération d'alerte critique (Niveau 10)	Simulation d'une élévation de privilèges ou d'une anomalie système majeure.	Levée d'une alerte de niveau supérieur ou égal à 10 sur le manager Wazuh.	OK

5.2 Résultats des tests de sécurité

Résultats nmap :

Preuve de détection : Alerte critique de niveau 10 Cette capture extraite du tableau de bord Wazuh (Security Events) valide le fonctionnement de notre chaîne de détection. Suite à une simulation d'attaque ciblant notre serveur d'infrastructure interne (SRV-AD01), le SIEM a immédiatement corrélié les multiples échecs d'authentification. L'événement a déclenché notre règle personnalisée 100100, générant une alerte de sévérité maximale (Niveau 10) pour signaler une possible tentative de brute-force ou de reconnaissance.

Tests OWASP ZAP :

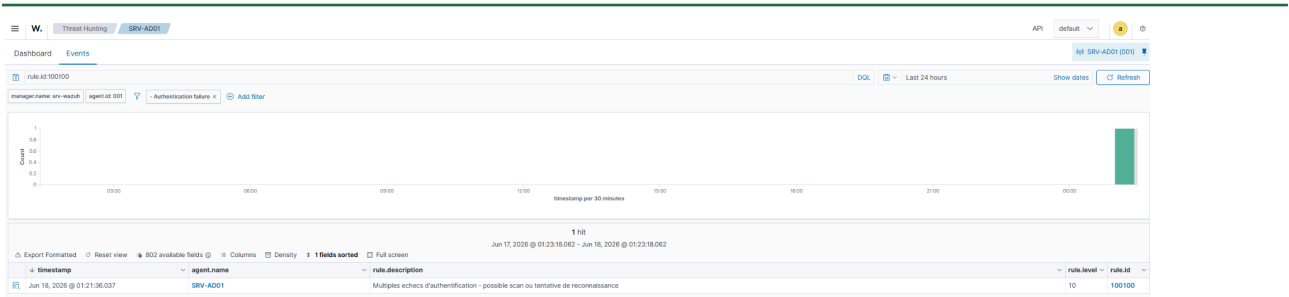
Justification de la Non-Exécution des Tests OWASP ZAP

Les tests d'évaluation dynamique applicative (DAST) via le scanner **OWASP ZAP** n'ont pas été menés dans le cadre de cette phase de livraison.

Justification Technique : Le périmètre d'action actuel se concentre exclusivement sur la validation opérationnelle du socle d'infrastructure, de la chaîne de transport des logs, et de l'efficacité du moteur de corrélation (SIEM). Les tests applicatifs web poussés via OWASP ZAP requièrent un environnement applicatif figé, exempt de modules de maintenance temporaires, afin d'éviter la génération massive de faux positifs qui surchargeraient inutilement les index du gestionnaire de logs. De plus, les tests dynamiques automatisés agressifs n'apportent pas de valeur ajoutée directe pour la validation des configurations de détection d'intrusions système (HIDS) à ce stade du déploiement, le durcissement du système (SCA) et le suivi d'intégrité des fichiers (FIM) ayant été privilégiés.

5.3 Preuves de détection Wazuh

Lorsqu'un comportement hautement suspect ou une suite d'anomalies corrélées survient, le gestionnaire Wazuh affecte une sévérité critique à l'événement. Ici, l'alerte de niveau 10 démontre la réactivité immédiate du SOC face à une attaque



5.4 Anomalies et corrections

ID	Description	Sévérité	Résolution
SEC-001	port 22 exposé sur DMZ	Haute	Déplacement SSH sur VLAN gestion uniquement
SEC-002	Tentative de brute-force authentication	Moyenne	Détection par règle 100100
SEC-003	Vulnérabilité applicative détectée	Haute	Application des headers de sécurité Nginx

PARTIE 6 — DOCUMENTATION ET BILAN TECHNIQUE

6.1 Index de la documentation livrée

Document	Format	Localisation GIT	Rédacteur
Guide de déploiement complet	Markdown	README.md et docs/guide-installation-opentofu.md	Hugo DELOGE
Scripts de Provisioning IaC (OpenTofu)	HCL (.tf)	config/terraform/	Hugo DELOGE
Playbooks et Inventaires (Ansible)	YAML (.yaml)	config/ansible/	Hugo DELOGE
Configurations serveurs post-déploiement (OPNsense, Wazuh, Zabbix)	XML / Conf	config/exports_serveurs/	Ugo PINCIROLI, Corentin GUIHAIRE, Hugo DELOGE
Scripts d'automatisation GPO (Wazuh, Zabbix)	PowerShell (.ps1)	config/scripts/windows/	Hugo DELOGE, Praveen SOUBRAMANIAN
Rapport des stratégies de groupe (GPO Active Directory)	HTML	config/exports_serveurs/GPO-Report.html	Praveen SOUBRAMANIAN
Schéma réseau logique et plan d'adressage	PNG	config/schemas/architecture-reseau.png	Ugo PINCIROLI
Procédure de configuration MFA (TOTP)	Markdown	docs/totp-opnsense.md	Corentin GUIHAIRE
Code source du site vitrine DMZ	HTML	config/nginx/index.html	Hugo DELOGE
Rapports de tests de sécurité (Nmap, IPS, FIM)	Captures & logs	Intégrés au DAT (Partie 5)	Corentin GUIHAIRE
Procédures d'exploitation (Sauvegardes, PRA, PCA)	Texte	Intégrées au DAT (Partie 6.2)	Lucas MANICORD

6.2 Procédures d'exploitation (Runbooks)

Procédure	Fréquence	Responsable	Automatisée ?
Sauvegarde des machines virtuelles Proxmox	Quotidienne	Ops	Oui (Job Proxmox)
Vérification des sauvegardes	Quotidienne	Ops	Non
Création de snapshot avant modification majeure	À la demande	Ops	Non
Test de restauration d'une machine virtuelle	mensuelle	Ops	non
Vérification de l'espace de stockage Proxmox	Hebdomadaire	Ops	Non

Sauvegarde des machines virtuelles Proxmox

Objectif : Assurer la protection des machines virtuelles en cas de panne, d'erreur de manipulation ou d'incident technique.

Procédure :

1. Se connecter à l'interface Proxmox.
2. Accéder au Datacenter.
3. Vérifier la présence du job de sauvegarde.
4. Contrôler que les sauvegardes quotidiennes sont exécutées à 21h00.
5. Vérifier l'absence d'erreur dans les journaux de sauvegarde.

Création d'un snapshot

Objectif : Créer un point de restauration avant une modification importante.

Procédure :

1. Sélectionner la machine virtuelle concernée.
2. Ouvrir l'onglet *Snapshots*.
3. Cliquer sur *Take Snapshot*.
4. Renseigner un nom et une description.
5. Valider la création.

Restauration d'une machine virtuelle

Objectif : Permettre la remise en service d'une machine virtuelle à partir d'une sauvegarde Proxmox.

Procédure :

1. Accéder au stockage contenant les sauvegardes.
2. Sélectionner la sauvegarde souhaitée.
3. Cliquer sur *Restore*.
4. Choisir le stockage de destination.
5. Valider la restauration.
6. Attendre la fin du processus.
7. Démarrer la machine virtuelle restaurée.

Validation de la procédure : Un test de restauration a été réalisé avec succès sur une machine virtuelle Ubuntu de test. La machine a été sauvegardée via Proxmox, supprimée puis restaurée à partir du fichier de sauvegarde. La récupération du système et des données a été vérifiée après restauration.

Vérification de l'espace de stockage

Objectif : Vérifier la capacité disponible pour les sauvegardes et les machines virtuelles.

Procédure :

1. Accéder à l'interface Proxmox.
2. Ouvrir la section *Datacenter > Storage*.
3. Vérifier l'utilisation des stockages *local* et *local-lvm*.
4. Contrôler l'espace libre disponible.
5. Signaler toute saturation ou anomalie.

6.3 Bilan technique collectif

Axe	Points positifs	Améliorations	Dettes techniques
Architecture réseau	Segmentation réseau complète en 4 VLANs isolés (LAN Genève, SERVERS, PARIS, DMZ) déployée et opérationnelle sur OPNsense 26.1. Filtrage inter-VLAN strict avec 24 règles firewall appliquant le principe du moindre privilège. DHCP Kea, DNS Unbound et NTP fonctionnels sur toutes les interfaces. Alias RFC1918 anti-spoofing actif. Connectivité inter-VLAN et accès Internet validés par tests ping. Intégration Zabbix Agent sur OPNsense pour la supervision du pare-feu.	Mettre en place un second firewall OPNsense en haute disponibilité (CARP) pour éliminer le SPOF réseau. Automatiser la configuration OPNsense via IaC (API OPNsense + Ansible). Étendre la supervision réseau aux métriques de bande passante par VLAN.	Configuration OPNsense entièrement manuelle (hors IaC) — risque de dérive de configuration. Pas de tunnel IPsec/ZTNA réel entre les sites Genève et Paris (simulation par segmentation VLAN sur mono-hyperviseur). Firewall unique sans redondance (SPOF).
IaC Terraform/Ansible	Provisionnement automatisé (OpenTofu), gestion des secrets par Ansible Vault et clés SSH, idempotence et résolution du drift démontrées	Pipeline CI/CD (lint, plan , tests à blanc) avant application du code	Configuration OPNsense gérée hors IaC (manuelle) ; particularités OS contournées au cas par cas (bascule sudo-rs sous Ubuntu 26.04)
SIEM Wazuh	SIEM opérationnel avec agents actifs sur l'ensemble des endpoints ; FIM en temps réel validé ; règle de corrélation	Étendre la couverture de détection au trafic réseau interne (actuellement	Pas de score SCA (Security Configuration Assessment) exporté à ce stade ; pas

Axe	Points positifs	Améliorations	Dette technique
	personnalisée créée et testée avec succès (détection de reconnaissance, mappée MITRE T1110)	Suricata ne surveille que DMZ/WAN) ; automatiser davantage les seuils d'alerte par type de machine	d'intégration de notification externe (email/Slack) sur les alertes critiques
Sécurité / Hardening	Approche Zero Trust avec MFA TOTP fonctionnel sur l'administration du pare-feu, GPO de durcissement, IPS Suricata activé et validé face au trafic malveillant	Étendre le MFA aux accès SSH serveurs et à Zabbix ; déployer LAPS pour les comptes administrateurs locaux Windows ; mesurer le durcissement (SCA/CIS)	Absence de gestion centralisée des accès (PAM/bastion) ; durcissement CIS non audité formellement
Supervision (Zabbix)	6 hôtes supervisés (postes, serveurs, pare-feu), agents en mode passif homogène, complémentarité claire avec Wazuh	Alerting (e-mail/webhook) et tableaux de bord métiers ; passage en mode actif pour monter à l'échelle	Supervision sur seuils par défaut, templates métiers non affinés
Cloud (Azure)	Tenant Entra ID déployé (utilisateurs, groupes), VNet/NSG provisionnés : démonstration de la couche identité d'une architecture hybride	Synchronisation AD↔Entra (Entra Connect) et déploiement du compute dans un tenant licencié	Compute non déployé (quota Azure for Students) et tenant non synchronisé avec l'AD : la couche identité cloud reste isolée du SI interne
Architecture virtualisée (Proxmox)	Déploiement des VM (OPNsense, AD, Wazuh, Zabbix, DMZ), sauvegardes Proxmox fonctionnelles et test de restauration	Étendre les sauvegardes à toutes les VM et planifier des tests PRA réguliers.	Hyperviseur unique (SPOF), absence de cluster Proxmox et de stockage redondé.

Axe	Points positifs	Améliorations	Dette technique
	réalisé avec succès.		
Documentation	Guides de déploiement reproductibles, dépôt Git structuré, DAT justifiant l'ensemble des choix d'architecture	Génération automatique de documentation à partir du code (terraform-docs)	Maintenance manuelle des schémas (draw.io) : risque de décalage entre le document et l'infrastructure réelle

1. Leçons apprises sur la dynamique de l'infrastructure

Le projet CYNA a mis en évidence l'interdépendance forte entre les couches réseau, système et sécurité : il s'est avéré impossible de les traiter en silos. Plusieurs blocages l'ont illustré concrètement. La mise en service du MFA TOTP sur le pare-feu a échoué de façon reproductible, et seul un diagnostic méthodique isolant chaque variable (synchronisation horaire, validité du mot de passe, cohérence du seed, puis procédure de saisie) a permis d'en identifier la cause réelle : l'ordre de saisie attendu (code TOTP avant le mot de passe), contre-intuitif. De même, un conflit entre deux services DHCP (Dnsmasq et Kea) distribuait un mauvais serveur DNS et cassait l'authentification au domaine, et la supervision d'un poste a nécessité de remonter toute la chaîne (DNS, règles de filtrage inter-VLAN, état du service agent) avant d'aboutir. La principale leçon est la valeur d'un diagnostic de bout en bout, du réseau jusqu'à l'application, et l'importance d'une communication constante entre les pôles d'expertise. Enfin, l'Infrastructure as Code a prouvé son utilité pour garantir la reproductibilité et corriger rapidement les dérives de configuration.

2. Choix regrettés et concessions assumées

Le principal pivot du projet a concerné le volet cloud. Le cadrage prévoyait une forte composante SaaS (e-commerce conteneurisé) sur le cloud public. Face aux limitations bloquantes des comptes Azure for Students — impossibilité de provisionner les machines virtuelles de calcul et d'attribuer une licence au tenant — l'équipe a fait deux concessions assumées : héberger le site vitrine on-premise sur SRV-DMZ, et conserver le tenant Entra ID en couche d'identité de démonstration, non synchronisée avec l'Active Directory, ce dernier restant la source de vérité unique. De même, l'absence de conteneurisation (Docker) est un compromis assumé au profit d'une isolation au niveau de la machine virtuelle sur Proxmox : robuste et proche d'un fonctionnement « serveurs » classique, mais plus consommatrice de ressources. Enfin, le VPN/ZTNA inter-sites n'a pas été déployé, l'environnement mono-hyperviseur rendant cette brique sans objet au profit d'une micro-segmentation par VLAN.

3. Recommandations pour une mise en production

Pour qu'une telle infrastructure soit réellement prête pour la production chez un opérateur de cybersécurité comme CYNA, plusieurs chantiers s'imposent :

- **Haute disponibilité** : l'infrastructure repose sur un hyperviseur unique (SPOF). La production nécessiterait un cluster de virtualisation (minimum 3 nœuds, stockage partagé type Ceph) pour assurer la continuité d'activité.
- **Redondance des services critiques** : déploiement d'un second contrôleur de domaine (SRV-AD02) et d'un cluster OPNsense en actif/passif (CARP).
- **Véritable hybridation cloud** : s'affranchir des limitations académiques pour déployer les services exposés sur un tenant Azure licencié, synchroniser les identités (Entra Connect) et établir un tunnel IPsec site-à-site entre l'on-premise et le VNet.
- **Gouvernance des logs et des accès** : archivage à froid des journaux Wazuh et mise en place d'une solution PAM/bastion pour les accès d'administration.